



SECURITY ASSESSMENT REPORT

脆弱性診断報告書

Web アプリケーション セキュリティ 診断

http://127.0.0.1:8899

診断対象	http://127.0.0.1:8899
診断実施日	2026-07-15
報告書発行日	2026-07-15
実施者	AllAmbitious セキュリティ診断チーム
認可の根拠	社内検証環境（ローカルフィクスチャ・書面認可相当）
文書番号	WVR-20260715

CONFIDENTIAL / 取扱注意

本報告書は診断対象組織の機密情報を含みます。関係者以外への開示・複製・二次配布を禁じます。記載の検出事項は診断時点のスナップショットであり、対策実装後の再診断を推奨します。

目次

1	エグゼクティブサマリ	3
2	診断範囲と手法	4
3	検出事項の詳細	5
4	付録	11

重大度の凡例 / SEVERITY LEGEND

緊急 Critical	CVSS 9.0-10.0	即時対応。悪用が容易で影響が甚大。
重要 High	CVSS 7.0-8.9	優先対応。重大な情報漏洩・侵害の起点となりうる。
警告 Medium	CVSS 4.0-6.9	計画的に是正。多層防御の不足など。
注意 Low	CVSS 0.1-3.9	影響は限定的。ベストプラクティスからの逸脱。
情報 Info	-	参考情報。直接の脆弱性ではない。

深刻度は CVSS 4.0 基本値 (CVSS-B) で評価し、検出事項を OWASP Top 10:2025 / CWE で分類、診断手法は WSTG、検証要件は ASVS 5.0.0 を参照する。総合評価はセキュリティグレード (A=安全 ~ F=危険) で示し、満点 100 からの減点式スコアと最も重い所見による上限 (キャップ) で決定する (A に近いほど安全)。

1 エグゼクティブサマリ



総合セキュリティ評価

危険

早急に対応すべき深刻な問題が確認されました。

安全

A+

A

B

C

D

F

危険

1

要優先対応（緊急・重要）

8.7

最大 CVSS-B (4.0)

4

診断ページ数

緊急（Critical）級の脆弱性は検出されていません。低評価は重要（High）級所見と設定不備の累積によるものです。

本診断では、認可された検証環境に対し非破壊手法で 14 件の指摘事項を検出した。最も優先度が高いのは **機微ファイル（.git / .env）の公開**（VWR-001, CVSS 7.5）であり、ソースコードや認証情報の漏洩に直結しうるため即時是正を要する。次いで、**入力値の無害化されない反射**（反射型 XSS の兆候）、**オープンリダイレクト**、**危険な HTTP メソッドの有効化**が、フィッシングやセッション窃取の起点となりうる。

全体傾向として、セキュリティヘッダ（CSP・X-Content-Type-Options・クリックジャッキング対策）の未整備が全ページに横断し、多層防御が不足している。これらは単体の深刻度は中～低だが、XSS 等の一次脆弱性と組み合わせると被害を拡大させる。まずは高深刻度の情報漏洩を塞ぎ、続いてヘッダ・Cookie 属性の全面適用へ進む二段構えを推奨する。

重大度別サマリ

緊急 CRITICAL 0	重要 HIGH 1	警告 MEDIUM 5	注意 LOW 8	情報 INFO 0
----------------------------	------------------------	--------------------------	-----------------------	------------------------

主要な検出事項

ID	重大度	CVSS	所見	OWASP
VWR-001	重要	8.7	機微ファイル/ディレクトリの公開	A01:2025
VWR-002	警告	6.9	サーバ/フレームワークのバージョン露出	A01:2025
VWR-003	警告	6.9	ディレクトリリスティングが有効	A01:2025
VWR-004	警告	6.9	危険な HTTP メソッドが有効（TRACE/PUT/DELETE 等）	A02:2025

ID	重大度	CVSS	所見	OWASP
VWR-005	警告	5.1	オープンリダイレクトの可能性	A01:2025
VWR-006	警告	5.1	入力値の無害化されない反射（XSS の兆候）	A05:2025
VWR-007	注意	2.3	Referrer-Policy 未設定	A01:2025
VWR-008	注意	2.1	X-Content-Type-Options: nosniff 未設定	A02:2025

改善ロードマップ / 優先度

- 1. 即時（～1週間）**：.git / .env 等の機微ファイルを公開領域から除去し、Web サーバで拒否設定。漏洩した可能性のある認証情報はローテーションする。
- 2. 短期（～1か月）**：反射型 XSS・オープンリダイレクトの入力/出力検証を実装。不要な HTTP メソッド（TRACE/PUT/DELETE）を無効化。
- 3. 中期（～3か月）**：セキュリティヘッダ（CSP を Report-Only から段階導入、X-Content-Type-Options、X-Frame-Options、Referrer-Policy）と Cookie 属性（Secure/HttpOnly/SameSite）を全面適用。クライアントライブラリを最新化し SCA を CI に組み込む。
- 4. 継続**：是正後の再診断と、リリースパイプラインへの自動セキュリティチェック統合。

2 診断範囲と手法

診断対象	http://127.0.0.1:8899
スコープ（ホスト）	127.0.0.1
巡回ページ数	4
診断方式	ハイブリッド（内蔵チェック） / 非破壊
使用ツール	内蔵チェックエンジン
認可の根拠	社内検証環境（ローカルフィクスチャ・書面認可相当）
実施日時	2026-07-14 18:37 (UTC)

診断手法と評価基準（準拠標準）

本診断は次の標準に準拠する。診断手法は **OWASP WSTG**（Web Security Testing Guide、非破壊で機械的に検証可能な項目に限定）に基づき、検出事項を **OWASP Top 10:2025**（現行 公開版）と CWE で分類、深刻度は **CVSS 4.0 基本値（CVSS-B）** で評価し、検証要件は **OWASP ASVS 5.0.0**（該当する要件番号・レベルを所見に併記）を参照する。診断は認可された 範囲に限定し、データ改変・サービス妨害・破壊的操作を伴わない非破壊手法で実施している。

補足: (1) CVSS 4.0 のスコアは CVSS 3.1 と互換性がない（同一事象でも数値が異なる）。本報告書は Base のみ（CVSS-B、脅威情勢 E は最悪ケース前提）を用いる。(2) 一部のチェック（CSP・一部セキュリティヘッダ・SRI・混在コンテンツ）は WSTG v4.2 に専用テスト ID が無く、独自根拠で診断している。(3) CWE は本スキル独自付与（ASVS 5.0 は CWE 公式マッピングを廃止）。(4) 自動・非破壊診断 は ASVS の技術検証の一部であり、ASVS 認証・OWASP トラストマークを意味しない。

制約事項・免責

- ・本診断は非破壊の観測・安全な能動プローブに基づく。認証後領域や業務ロジックの詳細な検査（手動ペネトレーションテスト）は範囲外である。
- ・「古いコンポーネント」等の CVE 級判定は、外部脆弱性データベース（nuclei 等）を併用した項目に限る。内蔵チェックのみの結果は構成・衛生面の指摘であり、個別 CVE の成立を保証するものではない。
- ・検出事項は診断時点のスナップショットであり、以降の変更は反映されない。

3 検出事項の詳細

重要 / High

VWR-001

CVSS-B 8.7

確度 High

機微ファイル/ディレクトリの公開

`.git`/`.env`/バックアップ等の機微ファイルが公開領域から取得可能。

分類 A01:2025-アクセス制御の不備 / CWE-538

準拠参照 WSTG: WSTG-CONF-04 / ASVS: v5.0.0-13.4.1 (L1)

影響 ソースコード・認証情報・内部設定が漏洩し、深刻な侵害の起点となる。

対象 <http://127.0.0.1:8899/.git/HEAD>

<http://127.0.0.1:8899/.env>

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

HTTP 200 で取得可能（署名一致: 'ref: '）
（該当 2 箇所。詳細は「対象」欄を参照）

推奨対策: 当該ファイル/ディレクトリを公開領域から除去し、Web サーバで拒否する。

参考: <https://cwe.mitre.org/data/definitions/538.html>

警告 / Medium

VWR-002

CVSS-B 6.9

確度 Medium

サーバ/フレームワークのバージョン露出

Server/X-Powered-By 等でソフトウェアとバージョンが露出し、既知脆弱性の 標的選定を容易にしている。

分類 A01:2025-アクセス制御の不備 / CWE-200

準拠参照 WSTG: WSTG-INFO-02 / ASVS: v5.0.0-13.4.6 (L3)

影響 攻撃者による脆弱性探索の効率化。

対象 <http://127.0.0.1:8899>

<http://127.0.0.1:8899/search?q=hello>

<http://127.0.0.1:8899/go?url=/next>

<http://127.0.0.1:8899/files/>

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

バージョン露出: BaseHTTP/0.6 Python/3.11.15, TestServer/1.2.3
(該当 4 箇所。詳細は「対象」欄を参照)

推奨対策: バージョン情報の露出を抑制する (トークン非表示・バナー抑制)。

参考: <https://cwe.mitre.org/data/definitions/200.html>

警告 / Medium

VWR-003

CVSS-B 6.9

確度 High

ディレクトリリスティングが有効

自動インデックス表示が有効で、意図しないファイル一覧が閲覧できる。

分類 A01:2025-アクセス制御の不備 / CWE-548

準拠参照 WSTG: WSTG-CONF-04 / ASVS: v5.0.0-13.4.3 (L2)

影響 非公開ファイルの発見・情報収集を容易にする。

対象 <http://127.0.0.1:8899/files/>

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

自動インデックス表示の兆候 ('Index of ')

推奨対策: Web サーバの自動インデックスを無効化する ('Options -Indexes' 等)。

参考: <https://cwe.mitre.org/data/definitions/548.html>

警告 / Medium

VWR-004

CVSS-B 6.9

確度 High

危険な HTTP メソッドが有効 (TRACE/PUT/DELETE 等)

OPTIONS 応答で TRACE/PUT/DELETE 等が許可されている。

分類 A02:2025-セキュリティの設定ミス (暫定・2025 CWE リスト未確認) / CWE-650

準拠参照 WSTG: WSTG-CONF-06 / ASVS: v5.0.0-13.4.4 (L2)

影響 Cross-Site Tracing や意図しないリソース操作の余地がある。

対象 <http://127.0.0.1:8899>

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N

Allow ヘッダに危険メソッド: TRACE, PUT

推奨対策: 不要な HTTP メソッドを無効化し、必要なものだけ許可する。

参考: <https://cwe.mitre.org/data/definitions/650.html>

警告 / Medium

VWR-005

CVSS-B 5.1

確度 Medium

オープンリダイレクトの可能性

リダイレクト先パラメータが検証されず、任意 URL へ誘導できる兆候がある。

分類 A01:2025-アクセス制御の不備 / CWE-601

準拠参照 WSTG: WSTG-CLNT-04 / ASVS: v5.0.0-3.7.2 (L2)

影響 フィッシングや OAuth トークン窃取の踏み台になりうる。

対象 <http://127.0.0.1:8899/go?url=https%3A%2F%2Fvwr-redirect-probe.example.org%2F>

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:L/SI:L/SA:N

パラメータ 'url' がリダイレクト先に反映 (Location=https://vwr-redirect-probe.example.org/)

推奨対策: リダイレクト先を相対パスまたは許可リストに限定する。

参考: <https://cwe.mitre.org/data/definitions/601.html>

警告 / Medium

VWR-006

CVSS-B 5.1

確度 Medium

入力値の無害化されない反射 (XSS の兆候)

無害な検査マーカーが HTML エスケープされずに応答へ反射している。反射型 XSS の疑い。

分類 A05:2025-インジェクション / CWE-79

準拠参照 WSTG: WSTG-INPV-01 / ASVS: v5.0.0-1.2.1 (L1)

影響 スクリプト注入によりセッション窃取・改竄・なりすましが生じうる。

対象 <http://127.0.0.1:8899/search?q=vwrPR0BE9137%3C%22%27>

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:L/SI:L/SA:N

パラメータ 'q' の値が無害化されず反射 (マーカー検出)

推奨対策: 出力コンテキストに応じたエスケープ/サニタイズを施し、CSP を併用する。

参考: <https://owasp.org/www-community/attacks/xss/>

注意 / Low VWR-007 CVSS-B 2.3 確度 Medium

Referrer-Policy 未設定

リファラ制御が無く、URL に含まれる機微情報が外部サイトへ送出される余地がある。

分類 A01:2025-アクセス制御の不備 / CWE-200
準拠参照 WSTG: 該当なし（独自根拠） / ASVS: v5.0.0-3.4.5 (L2)
影響 トークンや内部パスを含む URL が第三者に漏れうる。
対象 `http://127.0.0.1:8899`
`http://127.0.0.1:8899/search?q=hello`
`http://127.0.0.1:8899/go?url=/next`
`http://127.0.0.1:8899/files/`

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:P/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

Referrer-Policy が未設定
(該当 4 箇所。詳細は「対象」欄を参照)

推奨対策: `Referrer-Policy: strict-origin-when-cross-origin` 等を設定する。

参考: <https://owasp.org/www-project-secure-headers/>

注意 / Low VWR-008 CVSS-B 2.1 確度 High

X-Content-Type-Options: nosniff 未設定

MIME スニффイング抑止ヘッダが無く、ブラウザがコンテンツ型を誤推定して スクリプトとして解釈する余地がある。

分類 A02:2025-セキュリティの設定ミス / CWE-16
準拠参照 WSTG: 該当なし（独自根拠） / ASVS: v5.0.0-3.4.4 (L2)
影響 アップロードファイル等を悪用したコンテンツ実行の一因となりうる。
対象 `http://127.0.0.1:8899`
`http://127.0.0.1:8899/search?q=hello`
`http://127.0.0.1:8899/go?url=/next`
`http://127.0.0.1:8899/files/`

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

X-Content-Type-Options: nosniff が未設定
(該当 4 箇所。詳細は「対象」欄を参照)

推奨対策: 全応答に `X-Content-Type-Options: nosniff` を付与する。

参考: <https://owasp.org/www-project-secure-headers/>

注意 / Low VWR-009 CVSS-B 2.1 確度 High

Content-Security-Policy (CSP) 未設定

CSP が無く、XSS 等のスクリプト注入に対する多層防御が欠如している。

分類 A06:2025-安全でない設計 / CWE-693

準拠参照 WSTG: 該当なし（独自根拠） / ASVS: v5.0.0-3.4.3 (L2)

影響 XSS の被害範囲を限定できず、任意スクリプト実行の影響が拡大しうる。

対象 <http://127.0.0.1:8899>
<http://127.0.0.1:8899/search?q=hello>
<http://127.0.0.1:8899/go?url=/next>
<http://127.0.0.1:8899/files/>

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:A/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N

Content-Security-Policy ヘッダが存在しない
(該当 4 箇所。詳細は「対象」欄を参照)

推奨対策: 適切な `Content-Security-Policy` を段階的に導入する（まず `default-src 'self'` を Report-Only で検証）。

参考: https://owasp.org/www-community/controls/Content_Security_Policy

注意 / Low VWR-010 CVSS-B 2.1 確度 High

クリックジャッキング対策 (X-Frame-Options / frame-ancestors) 未設定

フレーム埋め込み制限が無く、UI を重ねてユーザー操作を騙し取るクリックジャッキングが可能。

分類 A06:2025-安全でない設計 / CWE-1021

準拠参照 WSTG: WSTG-CLNT-09 / ASVS: v5.0.0-3.4.6 (L2)

影響 利用者の意図しない操作（送金・設定変更等）を誘発されうる。

対象 <http://127.0.0.1:8899>
<http://127.0.0.1:8899/search?q=hello>
<http://127.0.0.1:8899/go?url=/next>
<http://127.0.0.1:8899/files/>

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:A/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N

X-Frame-Options も CSP frame-ancestors も未設定
(該当 4 箇所。詳細は「対象」欄を参照)

推奨対策: `X-Frame-Options: DENY`（または `SAMEORIGIN`）と CSP `frame-ancestors 'self'` を設定する。

参考: <https://owasp.org/www-community/attacks/Clickjacking>

注意 / Low

VWR-011

CVSS-B 2.1

確度 Low

Permissions-Policy (旧 Feature-Policy) 未設定

ブラウザ機能（カメラ・位置情報・全画面等）の利用制限ポリシーが未設定で、埋め込みコンテンツや XSS 時に機能を濫用される余地がある。

分類 A06:2025-安全でない設計 / CWE-693

準拠参照 WSTG: 該当なし（独自根拠） / ASVS: 該当なし

影響 第三者コンテンツによるカメラ/位置情報等の機能濫用の一因となりうる。

対象 <http://127.0.0.1:8899>

<http://127.0.0.1:8899/search?q=hello>

<http://127.0.0.1:8899/go?url=/next>

<http://127.0.0.1:8899/files/>

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

Permissions-Policy (旧 Feature-Policy) が未設定
(該当 4 箇所。詳細は「対象」欄を参照)

推奨対策: `Permissions-Policy` で不要なブラウザ機能を明示的に無効化する。

参考: <https://owasp.org/www-project-secure-headers/>

注意 / Low

VWR-012

CVSS-B 2.1

確度 Medium

Cookie に HttpOnly 属性が無い

HttpOnly が無く、XSS 発生時に JavaScript から Cookie を読み取られる。

分類 A02:2025-セキュリティの設定ミス / CWE-1004

準拠参照 WSTG: WSTG-SESS-02 / ASVS: v5.0.0-3.3.4 (L2)

影響 XSS と組み合わせてセッションクッキーが窃取される。

対象 <http://127.0.0.1:8899>

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:A/VC:N/VI:N/VA:N/SC:L/SI:N/SA:N

Cookie 'SESSIONID' に HttpOnly 属性が無い

推奨対策: 認証系 Cookie に `HttpOnly` 属性を付与する。

参考: <https://owasp.org/www-community/HttpOnly>

注意 / Low VWR-013 CVSS-B 2.1 確度 Medium

Cookie に SameSite 属性が無い

SameSite が未指定で、CSRF に対する既定防御が弱い。

分類 A01:2025-アクセス制御の不備 / CWE-1275

準拠参照 WSTG: WSTG-SESS-02 / ASVS: v5.0.0-3.3.2 (L2)

影響 クロスサイトリクエストフォージェリの成立余地が広がる。

対象 <http://127.0.0.1:8899>

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:A/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N

Cookie 'SESSIONID' に SameSite 属性が無い

推奨対策: `SameSite=Lax` (または要件に応じ `Strict`) を設定する。

参考: <https://owasp.org/www-community/SameSite>

注意 / Low VWR-014 CVSS-B 2.1 確度 Low

古い可能性のあるクライアントライブラリの使用

既知の古いバージョン痕跡を持つ JS ライブラリを検出。CVE 断定には外部 DB (nuclei 等) 併用が必要。

分類 A03:2025-ソフトウェアサプライチェーンの障害 / CWE-1104

準拠参照 WSTG: 該当なし (独自根拠) / ASVS: v5.0.0-15.2.1 (L1)

影響 既知脆弱性を含む場合、XSS/プロトタイプ汚染等の影響を受けうる。

対象 <http://127.0.0.1:8899>

CVSS ベクタ CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:A/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N

古い可能性のあるライブラリ参照: js: /static/jquery-1.8.3.min.js

推奨対策: 依存ライブラリを最新の安定版へ更新し、SCA を継続導入する。

参考: <https://owasp.org/www-project-dependency-check/>

4 付録

4.1 巡回したエンドポイント (抜粋)

URL	状態	技術情報
http://127.0.0.1:8899	200	Server: BaseHTTP/0.6 Python/3.11.15, TestServer/1.2.3; js: /static/jquery-1.8.3.min.js
http://127.0.0.1:8899/search?q=hello	200	Server: BaseHTTP/0.6 Python/3.11.15, TestServer/1.2.3

URL	状態	技術情報
http://127.0.0.1:8899/go?url=/next	302	Server: BaseHTTP/0.6 Python/3.11.15
http://127.0.0.1:8899/files/	200	Server: BaseHTTP/0.6 Python/3.11.15, TestServer/1.2.3

本報告書は http://127.0.0.1:8899 に対する認可済み脆弱性診断（文書番号 WVR-20260715）の結果であり、記載情報は 機密 として取り扱うこと。診断は非破壊手法で実施し、検出事項は診断時点のものである。対策の実装後は 再診断を推奨する。使用ツール: 内蔵チェックエンジン。